

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

TALLER No. 15
Políticas de Seguridad en Redes y Dispositivos Finales

Fecha de entrega: 16/01/2026

1. Objetivo del taller

Identificar, documentar y evaluar controles de seguridad aplicando COBIT 2019 y normas técnicas internacionales.

2. Escenario del taller

El taller se realizó en un entorno simulado de una empresa ficticia (TechnoMart S.A.), y fue desarrollado de manera individual por los estudiantes desde sus hogares. Cada participante analizó el caso de estudio proporcionado, el cual describe una organización de comercio electrónico con infraestructura de red, servidores y dispositivos finales, presentando múltiples deficiencias de seguridad en redes, endpoints y gobernanza.

La actividad se llevó a cabo utilizando recursos virtuales y documentales, sin acceso a sistemas reales, lo que permitió evaluar configuraciones, identificar riesgos y proponer controles de seguridad de forma segura. Los estudiantes aplicaron COBIT 2019 y normas técnicas internacionales (ISO/IEC) para identificar, documentar y evaluar controles de seguridad, elaborando políticas, procedimientos y planes de remediación desde un contexto académico y controlado.

3. Desarrollo del taller / Procedimiento

Actividad 1: Mapeo de Objetivos COBIT

Actividad 2: Jerarquía Documental

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Actividad 3: Matriz de Hallazgos y Evaluación de Riesgos

Tabla 5: Matriz de Hallazgos de Seguridad en Redes

ID	Hallazgo	Activo Afectado	Amenaza Potencial	Vulnerabilidad Técnica	Impacto	Probabilidad	Riesgo	Control Compensatorio o Propuesto	Objetivo COBIT	Prioridad
r01	Tráfico sin cifrar en red interna	Red LAN completa	Intercepción de Credenciales y datos (sniffing)	Sin TLS/SSL entre cliente-servidor, sin IPSec	Alto	Alta	Alto	Implementar TLS 1.3 para aplicaciones web, VPN site-to-site con IPSec, segmentación de red	DSS05.0 2	1

Tabla 6: Matriz de Hallazgos de Seguridad en Endpoints

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID	Hallazgo	Activo Afectado	Amenaza Potencial	Vulnerabilidad Técnica	Impacto	Probabilidad	Riesgo	Control Compensatorio Propuesto	Objetivo COBIT	Prioridad
E01	60% sin antivirus y 40% desactualizado	180 equipos (estaciones y laptops)	Infección masiva por malware, ransomware	Falta de protección en tiempo real y firmas obsoletas	Alto	Alta	Alto	Desplegar solución antivirus corporativa centralizada con actualización automática	DSS05.0 1	1
E02	Ausencia de solución EDR	180 equipos (estaciones y laptops)	Ataques dirigidos (APTs) y malware de día cero	Falta de visibilidad de comportamiento y respuesta automatizada	Alto	Media	Alto	Implementar solución EDR (Endpoint Detection and Response) para análisis forense y contención	DSS05.0 1	1
E03	45% de sistemas sin parches por +6 meses	150 estaciones Windows	Explotación de vulnerabilidades conocidas (CVEs)	Sistema operativo y aplicaciones críticas desactualizadas	Alto	Alta	Alto	Implementar un sistema de gestión de parches (WSUS/Endpoint Manager) y ciclos de parcheo mensuales	BAI06	1

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID	Hallazgo	Activo Afectado	Amenaza Potencial	Vulnerabilidad Técnica	Impacto	Probabilidad	Riesgo	Control Compensatorio Propuesto	Objetivo COBIT	Prioridad
E04	Privilegios de administrador local para todos	Todos los usuarios finales	Ejecución de código malicioso, cambios no autorizados	Exceso de privilegios en cuentas de usuario estándar	Medio	Alta	Alto	Eliminar derechos administrativos locales; implementar principio de "mínimo privilegio"	DSS05.0 4	2
E05	Laptops sin cifrado de disco (BitLocker)	30 laptops móviles	Exfiltración de datos sensibles por robo o pérdida	Información almacenada en texto claro en dispositivos portátiles	Alto	Media	Alto	Forzar cifrado de disco completo (FDE) mediante BitLocker o similar gestionado por GPO	DSS05.0 3	2
E06	Sin gestión centralizada (AD/GPO)	200 empleados/dispositivos	Configuraciones inseguras inconsistentes en la red	Falta de aplicación uniforme de políticas de seguridad	Medio	Alta	Alto	Implementar Active Directory para gestión centralizada de identidades y políticas (GPO)	DSS05.0 3	2

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID	Hallazgo	Activo Afectado	Amenaza Potencial	Vulnerabilidad Técnica	Impacto	Probabilidad	Riesgo	Control Compensatorio Propuesto	Objetivo COBIT	Prioridad
E07	Sin control de puertos USB y autorun habilitado	180 equipos (estaciones y laptops)	Introducción de malware externo, fuga de datos	Puertos físicos abiertos sin restricciones de hardware	Medio	Alta	Alto	Deshabilitar Autorun/Autoplay y restringir el uso de medios extraíbles no autorizados	DSS05.03	3
E08	Uso de software pirata (30%)	54 estaciones aprox.	Puertas traseras (backdoors), inestabilidad, multas legales	Instalación de binarios de procedencia dudosa sin soporte	Medio	Media	Medio	Realizar inventario de software y sustituir aplicaciones piratas por licencias oficiales o alternativas Open Source	BAI06	3

Tabla 7: Matriz de Hallazgos de Gestión y Gobernanza (Mínimo 5)

ID	Hallazgo	Área Afectada	Consecuencia Organizacional	Impacto	Probabilidad	Riesgo	Acción Requerida	Objetivo COBIT	Prioridad
E01	Ausencia de Políticas y	Toda la organización	Inconsistencia en la aplicación de controles y toma	Alto	Alta	Alto	Redactar y aprobar el Manual de	APO01.03	1

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

	Procedimientos documentados.		de decisiones subjetiva sin base normativa.				Políticas de Seguridad de la Información (PSI) y procedimientos clave.		
E02	Inexistencia de estructura de gobierno (Sin CISO ni Comité).	Alta Gerencia / TI	Falta de responsabilidad clara (accountability) y liderazgo estratégico en seguridad.	Alto	Alta	Alto	Designar un Oficial de Seguridad (CISO) y establecer el Comité de Seguridad de la Información.	EDM01.01	1
E03	Personal sin capacitación ni concientización (Awareness).	Recursos Humanos / Todos	Aumento de vulnerabilidad ante ingeniería social (phishing) y errores humanos críticos.	Alto	Alta	Alto	Implementar un programa anual de concientización y capacitación en ciberseguridad.	APO07.03	2
E04	Ausencia de Gestión de Incidentes (Sin plan de respuesta/CSIRT).	Operaciones TI	Tiempos de recuperación prolongados e incapacidad para contener ataques activos.	Alto	Media	Alto	Desarrollar un Plan de Respuesta a Incidentes (IRP) y definir el	DSS02.05	1

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

							equipo de respuesta.		
E05	Falta de Auditorías y evaluaciones de vulnerabilidad (Pentesting).	Infraestructura / TI	Desconocimiento del estado real de seguridad y persistencia de brechas explotables.	Alto	Media	Alto	Ejecutar análisis de vulnerabilidades trimestrales y un pentesting anual externo.	MEA01.03	2

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Actividad 4: Diseño de Política de Seguridad de Endpoints

POLÍTICA DE SEGURIDAD DE ENDPOINTS - TECHNOMART S.A.

Código: POL-SI-002

Versión: 1.0

Fecha de aprobación: [Fecha]

Próxima revisión: [Fecha + 1 año]

Clasificación: Uso Interno

1) OBJETIVO

Esta política establece los requisitos mínimos de seguridad para todos los dispositivos finales (endpoints) de TechnoMart S.A., garantizando la protección de información corporativa y de clientes contra amenazas cibernéticas.

La presente política responde a los objetivos de gobernanza EDM03 (Asegurar la Optimización del Riesgo) de COBIT 2019, asegurando que el riesgo asociado al uso de endpoints esté dentro del apetito de riesgo aceptable. Operacionaliza los objetivos de gestión DSS05.01 (Proteger contra malware) y DSS05.03 (Gestionar la seguridad de los endpoints).

Dado que TechnoMart procesa información sensible de clientes y tarjetas de crédito, la ausencia de controles en endpoints representa un riesgo crítico de fuga de información, infección por ransomware y compromiso de sistemas críticos de negocio.

2) ALCANCE

Dispositivos incluidos:

- **Estaciones de trabajo (Windows, Linux)**
- **Laptops corporativas**
- **Smartphones y tablets corporativos**
- **Servidores**

Usuarios cubiertos:

- **Todos los empleados de TechnoMart S.A.**
- **Contratistas y terceros con acceso a equipos corporativos**

Exclusiones: Dispositivos en ambientes de desarrollo/laboratorio (requieren aprobación formal de excepción)

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

3) MARCO NORMATIVO Y REFERENCIAS

4) DEFINICIONES

5) RESPONSABILIDADES

6) DIRECTRICES DE SEGURIDAD

7) CUMPLIMIENTO Y SANCIONES

8) EXCEPCIONES

9) REVISIÓN Y ACTUALIZACIÓN

10) APROBACIONES

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Actividad 5: Plan de Remediación Priorizado

Tabla 8: Fase 1 - Remediación Inmediata (0-30 días)

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E06	Implementación de Active Directory y configuración de GPOs base.	Administrador de Servidores	Windows Server, Licencias CAL	\$0 (Existente)	10 días	100% de estaciones en dominio	Ninguna	DSS05.03
E03	Configuración de servidor WSUS para automatización de parches críticos.	Administrador TI	Servidor de red, Conexión internet	\$0	15 días	95% de sistemas parchados	Conectividad	BAI06
E04	Creación del Plan de Respuesta a Incidentes (Documento base).	Gerente TI / Líder Proyecto	Horas hombre, Plantillas NIST	\$0	15 días	Documento IRP aprobado por Gerencia	Ninguna	DSS02.05

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E01	Redacción de la Política General de Seguridad de la Información.	Gerente TI	Horas hombre, ISO 27001	\$0	20 días	Política firmada y comunicada	Ninguna	APO01.03

TOTAL FASE 1: Costo: \$ /Tiempo:

Tabla 9: Fase 2 - Remediación a Corto Plazo (1-3 meses)

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E01	Adquisición y despliegue de solución Antivirus Corporativa centralizada.	CISO / Jefe de TI	Presupuesto, Licencias, Agente SW	\$5,500	45 días	100% de cobertura y firmas al día	E06	DSS05.01
E05	Activación de cifrado de disco completo con	Soporte Técnico	Módulo TPM, GPO de cifrado	\$0	20 días	100% de laptops móviles cifradas	E06	DSS05.03

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
	BitLocker en laptops.							
E03	Contratación de plataforma de Awareness y campaña de Phishing ético.	RRHH / TI	Plataforma (ej. KnowBe4), Instructor	\$3,500	45 días	>90% personal capacitado y aprobado	E01	APO07.03

TOTAL FASE 2: Costo: \$23,000 / Tiempo: 60 días

Tabla 10: Fase 3 - Remediación a Mediano Plazo (3-6 meses)

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E02	Implementación de EDR para detección avanzada y respuesta automatizada.	Analista SOC / Consultoría	Software EDR, Consola Cloud	\$12,500	90 días	Visibilidad total de procesos sospechosos	E01	DSS05.01

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E07	Restricción de puertos USB y deshabilitación de Autorun por política.	Especialista GPO	Software de control de puertos	\$0	30 días	0 infecciones vía USB reportadas	E04	DSS05.03
E05	Contratación de servicio de Pentesting Caja Negra y Análisis de Vulnerabilidades.	CISO (si ya existe) / TI	Proveedor externo de Ciberseguridad	\$4,500	60 días	Informe de hallazgos y plan de corrección	E01	MEA01.03

TOTAL FASE 3: Costo: \$28,500 / Tiempo: 120 días

Tabla 11: Fase 4 - Mejora Continua (6-12 meses)

ID Hallazgo	Acción Específica	Responsable	Recursos Necesarios	Costo (USD)	Tiempo Implementación	Métrica de Éxito	Dependencias	Objetivo COBIT
E08	Regularización de software pirata por licencias	Gestión de Activos	Presupuesto compras, Auditoría	\$6,000	180 días	0 software no licenciado detectado	Inventario	BAI06

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

	oficiales o alternativas.							
E02	Formalización de la estructura de Gobierno: Contratación de CISO a tiempo completo.	Dirección General	Presupuesto anual de nómina	\$30,000 (anual)	180 días	CISO contratado y en funciones	Presupuesto	EDM01.01

TOTAL FASE 4: Costo: \$80,000 / Tiempo: 365 días

Tabla 12: Resumen Ejecutivo del Plan de Remediación

Actividad 6: Indicadores de Gestión (KPIs) para Seguridad (30 minutos)

Tabla 13: KPIs de Seguridad de Endpoints

Nombre Indicador (KPI)	Fórmula de Cálculo	Meta	Frecuencia a Medición	Responsable de Medición	Fuente de Datos	Objetivo COBIT	Acción si NO se cumple meta
------------------------	--------------------	------	-----------------------	-------------------------	-----------------	----------------	-----------------------------

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Porcentaje de Cobertura Antivirus	$\frac{\text{Equipos con AV activo y actualizado}}{\text{Total de estaciones y laptops}} \times 100$	100%	Mensual	Analista de Seguridad	Consola central de Antivirus (EDR/EPP)	DSS05.0 1	Despliegue forzado de agentes vía GPO y auditoría de red.
Efectividad de Gestión de Parches	$\frac{\text{Equipos con parches críticos al día}}{\text{Total de estaciones y laptops}} \times 100$	$\geq 95\%$	Mensual	Administrador de TI	Reportes de cumplimiento o WSUS / Intune	BAI06	Ejecución inmediata de ventana de mantenimiento o extraordinaria
Nivel de Exposición por Privilegios	$\frac{\text{Usuarios finales sin permisos admin local}}{\text{Total de usuarios finales}} \times 100$	100%	Trimestral	Auditor de Sistemas	Reporte de Grupos Locales de Active Directory	DSS05.0 4	Revocación automática de permisos y re-aplicación de políticas de restricción.
Tasa de Cifrado de Información	$\frac{\text{Laptops con Bitlocker activo}}{\text{Total de laptops móviles}} \times 100$	95%	Mensual	Soporte Técnico	Panel de gestión de BitLocker / AD	DSS05.0 3	Bloqueo de acceso a la red para equipos no cifrados hasta

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

							regularización
--	--	--	--	--	--	--	----------------

Tabla 14: KPIs de Seguridad de Redes

Nombre Indicador (KPI)	Fórmula de Cálculo	Meta	Frecuencia Medición	Responsable Medición	Fuente de Datos	Objetivo COBIT	Acción si NO se cumple meta

Tabla 15: KPIs de Gestión y Gobernanza

Nombre Indicador (KPI)	Fórmula de Cálculo	Meta	Frecuencia	Responsable	Fuente de Datos	Objetivo COBIT	Acción si NO cumple
Nivel de Concientización en Seguridad	(Empeados que aprobaron curso / Total empleados) * 100	> 95%	Semestral	RRHH	Reporte Plataforma E-learning	APO07.03	Reentrenamiento obligatorio presencial.

 ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA		INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Cobertura de Políticas de Seguridad	(Procedimientos documentados / Procedimientos requeridos ISO 27001) * 100	100%	Anual	CISO	Repositorio Documental	APO01.03	Asignación de recursos externos para redacción.
Tasa de Resolución de Incidentes	(Incidentes resueltos dentro de SLA / Total incidentes) * 100	> 90%	Trimestral	Mesa de Ayuda	Sistema de Tickets (ITSM)	DSS02.05	Revisión del proceso de escalamiento y personal.
Cumplimiento de Auditoría	(Hallazgos remediados / Total hallazgos reportados) * 100	> 85%	Anual	Auditor Interno	Informe de Seguimiento Auditoría	MEA01.03	Sanción administrativa a dueños del riesgo.

PARTE IV: TRAZABILIDAD

1) Matriz de trazabilidad

ID	Descripción del Hallazgo	Objetivo COBIT Incumplido	Política Necesaria	Procedimiento Necesario	Control Propuesto	Norma Técnica	KPI de Seguimiento	Fase de Remediación
----	--------------------------	---------------------------	--------------------	-------------------------	-------------------	---------------	--------------------	---------------------

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

E0 1	Endpoints críticos expuestos sin autenticación	DSS05.04 (Gestión de acceso lógico)	Política de Control de Acceso	Implementación de Guards de Auth	Middleware de validación JWT obligatorio	ISO 27002:9.2 .1	% de endpoints sin auth	Fase 1
E0 2	Exposición de datos sensibles (PII) en los esquemas de respuesta JSON.	APO14.01 (Gestión de datos)	Política de Protección de Datos	Uso de Interceptores de Respuesta	Implementación de Class-Transformer (Exclude)	ISO 27002:8.1 1	# de fugas detectadas	Fase 2
E0 3	Falta de validación de tipos en los parámetros de entrada (DTOs).	BAI03.05 (Seguridad de infraestructura)	Política de Desarrollo Seguro	Validación de Esquemas (Class-Validator)	Uso de ValidationPipe global en el API	ISO 27002:8.2 5	% de inputs validados	Fase 1
E0 4	Ausencia de límites de peticiones (Rate Limiting) en el API Gateway.	DSS03.01 (Identificación de problemas)	Política de Disponibilidad	Configuración de Throttling	Implementación de módulo @nestjs/throttler	ISO 27002:8.2 6	Tps (Transacciones por seg)	Fase 2

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

E05	Registro insuficiente de logs de auditoría en cambios de identidad.	DSS05.07 (Monitoreo de seguridad)	Política de Logs y Monitoreo	Implementación de Logger Centralizado	Interceptor de auditoría para métodos POST/PATCH	ISO 27002:8.15	% eventos registrados	Fase 3
E01	Ausencia de políticas documentadas	APO01.03 (Gestión del Marco)	Política General de Seguridad (PSI)	Procedimiento de Creación de Documentos	Aprobación formal de la PSI por Directorio	ISO 27002:5.1	Cobertura de Políticas	Fase 1
E02	Inexistencia de CISO/Comité	EDM01.01 (Establecimiento Marco Gobierno)	Política de Organización de la Seguridad	Procedimiento de Toma de Decisiones de TI	Designación de roles y responsabilidades	ISO 27002:5.4	N/A (Hito)	Fase 4
E03	Personal sin capacitación	APO07.03 (Mantener habilidades)	Política de RRHH / Seguridad	Procedimiento de Inducción de Seguridad	Programa de Awareness y Phishing	ISO 27002:6.3	Nivel de Concientización	Fase 2
E04	Sin gestión de incidentes	DSS02.05 (Resolver incidentes)	Política de Gestión de Incidentes	Procedimiento de Respuesta y Notificación	Plan de Respuesta (IRP) documentado	ISO 27002:5.24	Tasa Resolución Incidentes	Fase 1
E05	Falta de Auditorías/Pentest	MEA01.03 (Supervisar cumplimiento)	Política de Auditoría y Cumplimiento	Procedimiento de Gestión de Vulnerabilidades	Ejecución de Pentesting externo	ISO 27002:8.8	Cumplimiento de Auditoría	Fase 3

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

4. Resultados obtenidos

De esta forma se presentan los hallazgos más críticos identificados durante la auditoría simulada a TechnoMart S.A., contrastando la evidencia encontrada con los controles de la norma ISO/IEC 27001:2022.

CONTROL / ÁREA AUDITADA	HALLAZGO	EVIDENCIA	NORMA O LITERAL CONTRASTADO
POLÍTICAS DE SEGURIDAD	No existe un marco normativo ni políticas definidas.	Ausencia total de documentación (Políticas, Procedimientos, Manuales) reportada en la entrevista de contexto.	ISO/IEC 27001:2022, Control 5.1 (Políticas para la seguridad de la información).
SEGURIDAD DE LAS REDES	Tráfico de red sin cifrar (uso de Telnet y HTTP) y Wi-Fi insegura (WEP).	Configuraciones de routers con servicios de texto claro habilitados y protocolos obsoletos en APs.	ISO/IEC 27001:2022, Control 8.24 (Uso de criptografía) y 8.20 (Seguridad en redes).
PROTECCIÓN CONTRA MALWARE	El 60% de los endpoints no tiene antivirus y el 100% carece de EDR.	Inventario de software muestra ausencia de agentes de seguridad en 90 estaciones.	ISO/IEC 27001:2022, Control 8.7 (Protección contra malware).
GESTIÓN DE VULNERABILIDADES	Falta de parches de seguridad (sistemas desactualizados > 6 meses).	45% de estaciones Windows con actualizaciones críticas pendientes.	ISO/IEC 27001:2022, Control 8.8 (Gestión de vulnerabilidades técnicas).

5. Análisis y discusión

Los hallazgos revelan una postura de seguridad inmadura y reactiva en TechnoMart S.A., caracterizada por un incumplimiento generalizado de los objetivos de control de COBIT 2019, específicamente en el dominio EDM03 (Optimización del Riesgo). La correlación entre la falta de gobernanza (inexistencia de CISO y políticas) y las fallas técnicas es evidente: al no existir una dirección estratégica desde la alta gerencia (Gobernanza), los controles operativos en redes y endpoints no se implementan o se configuran de manera negligente (por ejemplo, el uso de WEP y Telnet en 2025).

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

Al comparar la situación actual con la norma ISO/IEC 27001:2022, se identifica que la organización falla tanto en controles preventivos (Antivirus, Hardening) como detectivos (EDR, Logs centralizados). La ausencia de segmentación de red y el otorgamiento indiscriminado de privilegios de administrador local crean una superficie de ataque plana, donde un incidente de *ransomware* podría propagarse lateralmente sin resistencia, comprometiendo la continuidad del negocio y las transacciones diarias de \$41,000 USD (promedio basado en ventas anuales). La actividad demostró que la implementación de tecnología sin políticas que la regulen (como firewalls con reglas "permitir todo") es ineficaz para la mitigación de riesgos reales.

6. Conclusiones

Se identificaron, clasificaron y evaluaron los riesgos críticos de seguridad en los dominios de redes, endpoints y gobernanza de TechnoMart S.A. La actividad permitió aplicar de manera práctica el marco de trabajo COBIT 2019 para mapear objetivos de negocio con objetivos de seguridad, y utilizar la norma ISO/IEC 27001:2022 para definir los controles técnicos faltantes, evidenciando una brecha significativa entre el estado actual de la infraestructura y las mejores prácticas internacionales.

Se evidenció que la raíz de las vulnerabilidades técnicas (como la falta de parches y cifrado) reside en la ausencia de gestión y gobierno corporativo. La carencia de políticas documentadas y roles definidos (CISO) impide la ejecución de procesos de mantenimiento y monitoreo, dejando a la organización expuesta a amenazas de alto impacto como robo de datos financieros y ataques de denegación de servicio. Esto subraya la necesidad urgente de priorizar la "Fase 1" del plan de remediación propuesto para establecer un control base inmediato.

Finalmente, se concluye que la seguridad de la información no es solo un problema tecnológico, sino un proceso de gestión integral. Implementar una jerarquía documental robusta (Políticas, Procedimientos, Registros) es el requisito previo indispensable para que las soluciones técnicas (Firewalls, EDR) funcionen eficazmente. El taller fortaleció la capacidad del grupo para auditar entornos complejos, justificar inversiones en seguridad mediante análisis de riesgo y diseñar planes de acción alineados con los objetivos estratégicos del negocio.

7. Referencias

[1] ISACA, *COBIT 2019 Framework: Introduction and Methodology*, Schaumburg, IL: Information Systems Audit and Control Association, 2018.

[2] ISO/IEC, *Information security, cybersecurity and privacy protection — Information security controls*, ISO/IEC 27002:2022, Ginebra, Suiza: International Organization for Standardization, 2022.

	ESCUELA POLITÉCNICA NACIONAL AUDITORÍA INFOMÁTICA	INFORME DE TALLER No.
NOMBRES:	ERICK BALLAS, JOEL DEFAZ, WILLIAM ENRIQUEZ, SANTIAGO MURILLO, ISMAEL TOALA	15

[3] OpenAI, “Prompt utilizado: ‘Generar análisis de riesgos basado en ISO 27001 y redacción de políticas de seguridad para caso de estudio TechnoMart’”, 2026. ChatGPT-4o. [Modelo de IA].

[4] Cátedra de Auditoría Informática, *Taller No. 15: Políticas de Seguridad en Redes y Dispositivos Finales*, Escuela Politécnica Nacional, 2025.